



Data Analytics

Website Privacy Compliance Scorer

MAMALIK Hanane

20 July, 2026

Table of content

1. Introduction, business use case and goal
2. Project planning
3. Data collection and data sources
4. Metadata and data dictionary
5. Data cleaning
6. Exploratory data analysis
7. Relational database
8. Entity-relationship diagram
9. SQL analysis and insights
10. Exposing the data through an API
11. Machine learning
12. Conclusions, limitations and GDPR

Introduction

1.1 Context

Under the GDPR and the guidelines published by European data protection authorities - in particular the French CNIL - refusing cookies must be as easy as accepting them. In practice this rule is widely ignored. Many websites present a prominent “Accept all” button while the reject option is buried in a secondary menu, styled to be nearly invisible, or - the case this project focuses on - present but functionally inert: the button exists, you click it, and the trackers keep running.

That last case is the interesting one, because it is invisible to the user and invisible to a purely visual audit. A regulator or a user can see whether a reject button exists. Neither can easily see whether clicking it changed anything.

1.2 Business use case

Compliance is a broad, partly legal judgement that cannot be fully automated. This project deliberately narrows to the single dimension that can be tested objectively, reproducibly and at scale:

When a website shows a reject button, does clicking it actually stop the tracking - or is the button purely decorative?

This is measurable: count the third-party trackers loaded before any interaction, click reject, reload, and count again. If the count does not fall to zero, the site is not honoring the refusal.

Two audiences would use this. A privacy or compliance officer needs to triage which sites in a portfolio to audit manually, since the manual audit is expensive. A regulator or consumer association needs to measure the size of the problem across a market rather than site by site.

1.3 Goal and objectives

The deliverable is an end-to-end data product that takes nothing but a URL and returns a compliance risk assessment. Concretely:

- Measure, at scale, how European and international websites behave on cookie consent - using an automated Selenium audit rather than a manual review.
- Store the measurements in a normalised relational database so the findings can be queried, joined and cross-checked instead of living in a flat file.
- Cross-validate the scraper’s own findings against a fully independent public dataset (HTTPArchive via BigQuery), so the conclusions do not rest on a single instrument.
- Train a model that predicts reject-button effectiveness from pre-consent signals only, so a site can be scored in seconds instead of the 30–60 seconds the full differential test requires - and so that sites where the test cannot run automatically can still be scored.
- Expose the results through a Streamlit application and a REST API.

1.4 Why a model rather than just measuring

This is the central design decision of the project, so it is worth stating early. The full differential test (click reject → reload → recount) is expensive and fragile: it takes 30–60 seconds per site, and it only completes on

roughly 38% of sites. It fails on the rest because there is no reject button, the banner lives inside a shadow DOM the automation cannot reach, the site detects the bot, or the page times out.

So the expensive test was run once, at scale, to generate ground-truth labels. The model then learns the relationship between cheap pre-consent signals and that expensive outcome, which means any site - including the 62% where the test cannot run - can be scored in seconds.

Project planning

The project was organized in seven sequential phases, each mapping to a numbered notebook in the repository. The notebook numbering is itself the project plan: the prefix of every file states which phase it belongs to and the order in which it must run.

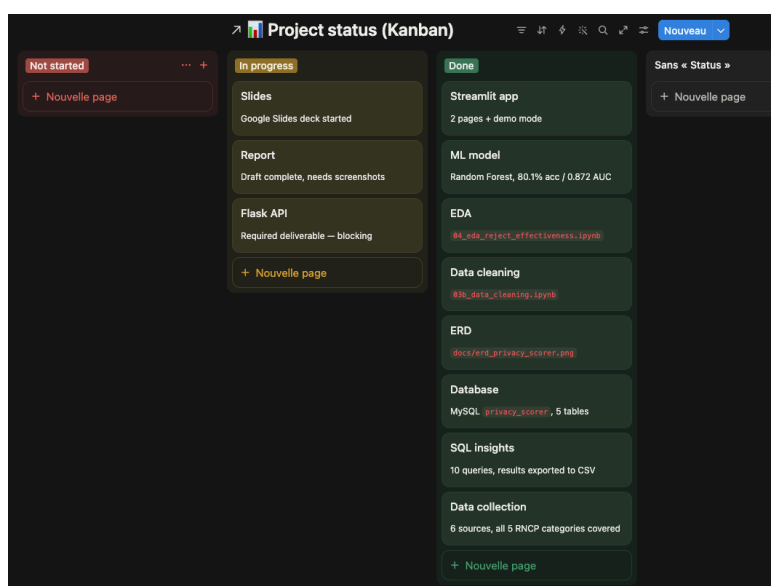


Table 1 — Project phases and the artefacts each produced.

An important planning decision was made at the end of phase 2. The first scraping pass produced a dataset in which the reject test had succeeded on too few sites to model, so the scraper was revised — better shadow-DOM traversal, longer waits, wider CMP signature list — and phase 2 was re-run over a larger target list. The superseded first-pass notebooks and outputs are kept in `archive/` rather than deleted, so the iteration is visible and auditable.

Data collection and data sources

#	Source	Category	Volume	Role in the project
1	Tranco top-sites list	Flat file (CSV)	5,000 URLs	Defines the population to audit
2	Selenium audit of live websites	Web scraping	4,100 sites	The primary measurement - all core variables
3	ip-api geolocation	REST API	4,100 lookups	Where the server actually sits; cloud/CDN flag
4	Google Safe Browsing	REST API	5,000 lookups	Independent reputation / safety control variable
5	HTTArchive via BigQuery	Big data system	5,000 pages	Independent cross-validation of the findings
6	Disconnect.me services.json	Reference file (JSON)	4,443 domains	The tracker catalogue the scraper matches against

Table 2 - The six data sources, covering all five RNCP-required categories.

3.1 Flat file - the Tranco top-sites list

Tranco is a research-grade ranking of the most visited domains, built by averaging several commercial ranking lists over a rolling 30-day window. It was chosen over the better-known Alexa-style lists precisely because it is designed to resist the manipulation and day-to-day volatility those lists suffer from, which matters when the list defines a research population.

It arrives as a plain CSV of rank and domain. Cleaning derived a market country from the top-level domain (.fr → France, .de → Germany) and a European / International region flag from that. This is an inference, not a measurement, and the report treats it as such - which is exactly why source 3 was added.

3.2 Web scraping - the Selenium audit

This is the heart of the project and the only source that can answer the research question, because the answer does not exist in any published dataset: it has to be produced by actually interacting with each site.

The scraper drives headless Chrome and, per site, performs a four-stage audit:

- **Pre-consent measurement** - load the page without touching anything; record every third-party request, match each domain against the Disconnect.me catalogue, and count trackers, ad networks, cookies, non-essential cookies and long-lived cookies.
- **Banner and CMP detection** - fingerprint the consent management platform (OneTrust, Didomi, Usercentrics, Cookiebot, Sourcepoint and others) from DOM signatures and script URLs; detect whether the IAB TCF API is present; record whether accept and reject buttons exist.
- **The differential reject test** - locate and click the reject control, traversing shadow DOM and iframes where required; reload the page; re-count trackers and cookies. The difference between the two counts is the ground truth this project is built on.

- **Context signals** - detect a linked privacy policy and the presence of robots.txt.

Of 5,000 URLs attempted, 4,100 produced a usable scan. The differential test itself completed on 1,583 of those - the modelling population.

```

> ✓
driver = create_driver()

all_results = []

for i, url in enumerate(url_list):
    driver = ensure_driver(driver)
    row = audit_site(driver, url)
    all_results.append(row)

    if (i + 1) % 100 == 0:
        print(f"Done {i+1} / {len(url_list)}")
        pd.DataFrame(all_results).to_csv("../raw_data/scraped_results_progress_new.csv", index=False)

driver.quit()

df_raw = pd.DataFrame(all_results)
df_raw.to_csv("../raw_data/scraped_results_new.csv", index=False)
print("Saved scraped_results_new.csv -", df_raw.shape)

[11]
... Done 100 / 5000
    Done 200 / 5000
    Done 300 / 5000
    Done 400 / 5000
    Done 500 / 5000
    Done 600 / 5000
    Done 700 / 5000
    Done 800 / 5000
    Done 900 / 5000
    Done 1000 / 5000
    Done 1100 / 5000

```

3.3 API 1 - IP geolocation (ip-api)

The Tranco-derived country is a guess from the domain suffix, and it fails completely on .com, .org and .net domains. This API resolves each domain to its server IP and returns the hosting country, the ISP, the owning organisation and an is_hosting flag indicating whether the address belongs to a commercial hosting or cloud provider.

This matters twice over. As an analytical variable it separates where a site sells from where it is hosted - the two genuinely differ, and Query 7 in section 9 shows several US media brands served from French infrastructure. As a modelling feature, the derived uses_major_cloud_cdn flag turned out to carry real signal, because sites on major cloud infrastructure are systematically more commercial.

It was chosen for the pragmatic reason that it needs no API key and its free tier permits 45 requests per minute, which is sufficient for 4,100 lookups.

3.4 API 2 - Google Safe Browsing

Every domain was checked against Google's malware and phishing blocklist. This was included as a control: the hypothesis was that sites behaving badly on consent might also be flagged for other reasons.

The result is a null finding, and it is reported as such because a null finding is still a finding. Not one site in the sample was flagged. This does not mean the check was wasted - it establishes that the population is made up

of ordinary, legitimate, popular websites. The consent failures documented in this report are therefore not the behaviour of fringe or malicious sites; they are the behaviour of the mainstream web. That framing strengthens the conclusion considerably.

3.5 Big data system - HTTPArchive via BigQuery

HTTPArchive crawls millions of websites monthly and publishes the results as a public BigQuery dataset running to many terabytes - far beyond what can be processed locally, which is precisely what makes it the appropriate big-data component rather than a token one.

The query used Wappalyzer-style technology detections to extract, for a 5,000-page sample, whether each page runs a consent management platform, analytics or advertising technology, plus a total technology count, page weight and request count. Because the underlying table is partitioned by crawl date and the technology data is nested, the query filters on the partition column first and unnests only the required fields - without that the scan cost is prohibitive.

The purpose is cross-validation. Every headline finding in this report is checked against this dataset, which was collected by a different organisation, with different instrumentation, on a different sample. Where the two agree, the finding is a property of the web rather than an artefact of one scraper.

3.6 Reference data - the Disconnect.me tracker catalogue

Deciding what counts as a tracker is the single most consequential judgement in the whole pipeline: a homemade list would make every tracker count arbitrary. This project therefore uses the Disconnect.me open catalogue - the same list that ships in Firefox's tracking protection - which maps 4,443 domains to a category and an owning company.

The file is deeply nested JSON (category → service → company → homepage → domains) and was flattened into one row per domain for loading into the database.

4. Metadata and data dictionary

The table below documents the analytical variables produced by the audit. The full dictionary covering all five database tables is in the repository.

Field	Type	Source	Definition
domain	VARCHAR	Tranco	Registrable domain; the join key across every source
country / region	VARCHAR	Derived	Market country inferred from the TLD; region = European / International
tracker_count	INT	Scraper	Distinct third-party domains matching the Disconnect catalogue, before any interaction
ad_network_count	INT	Scraper	Subset of the above in the Advertising category
cookies_before_interaction	INT	Scraper	Cookies set on load, before any consent choice
non_essential_cookies_before_interaction	INT	Scraper	Of those, cookies not strictly necessary - the ones that legally require prior consent
long_lived_cookies_count	INT	Scraper	Cookies with an expiry beyond the CNIL-recommended 13 months

Field	Type	Source	Definition
cmp_detected	VARCHAR	Scraper	Consent platform vendor fingerprinted from the DOM; "none" if unrecognised
tcf_api_present	BOOL	Scraper	Whether the IAB Transparency & Consent Framework API is exposed
has_cookie_banner	BOOL	Scraper	A consent banner was detected on load
has_accept_button / has_reject_button	BOOL	Scraper	Presence of each control within the banner
reject_as_visible_as_accept	BOOL	Scraper	Heuristic visual-parity check - collected but not modelled (see §12)
prechecked_boxes_detected	BOOL	Scraper	Consent options pre-ticked on load - invalid consent under GDPR
reject_click_attempted / _succeeded	BOOL	Scraper	Whether the automation reached and clicked reject; gates the target variable
tracker_count_after_reject	INT	Scraper	Trackers still loading after reject and reload - the outcome measurement
has_privacy_policy	BOOL	Scraper	A privacy policy link was detected
server_country / server_region	VARCHAR	ip-api	Where the server physically resolves - a measurement, not an inference
org / isp / is_hosting	VARCHAR / BOOL	ip-api	Owning organisation and whether it is a commercial hosting / cloud provider
flagged_unsafe	BOOL	Safe Browsing	Listed for malware or phishing (zero occurrences in this sample)
reject_test_looks_noisy	BOOL	Cleaning	Quality flag: post-reject tracker count exceeded the pre-consent count
has_cmp / has_analytics / has_advertising / tech_count	BOOL / INT	BigQuery	Independent technology detections used for cross-validation

Table 3 - Data dictionary for the principal analytical variables.

Data cleaning and Exploratory data analysis

5. Data cleaning

Cleaning is documented in 03b_data_cleaning.ipynb. Scraped data is messy in ways that flat-file data is not, because every value is the result of an interaction with a live, uncooperative website.

5.1 Categorical consolidation

The geolocation API returns country names inconsistently - “Netherlands” and “The Netherlands” arrive as distinct values and would split a single country across two groups in every aggregation. These were mapped to canonical forms.

The same problem, more severely, affects CMP vendor names, because two independent sources name the same vendor differently. A normalisation function lowercases, strips whitespace and maps known aliases to one canonical name before deduplication:

```
aliases = {
    'commanders act trustcommander': 'commanders act',
    'trustcommander': 'commanders act',
    'fundingchoices': 'funding choices',
    'snigel adconsent': 'snigel',
    # generic banners with no recognised vendor behind them
    'cookie notice': 'none',
    'custom cookie banner': 'none',
}
```

The second half of that mapping is a judgement worth defending: a page that shows a generic “cookie notice” with no identifiable vendor behind it is not using a consent management platform in any meaningful sense, so it is labelled “none” rather than being counted as a distinct vendor with one site.

5.2 Missing values that are not missing data

The most important cleaning decision concerns `tracker_count_after_reject`, which is null for roughly 62% of rows. Imputing it would have been a serious error. The null does not mean “the value is unknown”; it means the test could not run - there was no reject button, or the click could not be automated. Those rows have no ground truth and were therefore excluded from the modelling population rather than filled, leaving 1,583 sites with genuine labels.

5.3 Quality flagging

58 rows recorded more trackers after clicking reject than before it. That is physically implausible as a consent outcome and points to measurement noise - lazily loaded content, rotating ad slots, or a page that simply loaded differently on the second visit. Rather than silently dropping these rows, a `reject_test_looks_noisy` flag was added and carried through into the database, so the affected rows stay visible and queryable and any downstream analysis can decide for itself whether to exclude them.

5.4 Type correction and structural fixes

- Boolean columns arrived from CSV as object dtype with mixed string and boolean representations; all were cast to proper booleans so SQL and scikit-learn read them consistently.

- One row containing no real scraped data was removed.
- Country and region from the geolocation API were renamed to server_country and server_region before loading, so that joining sites to scans cannot silently collide two columns that share a name but mean different things - intended market versus physical hosting location.

6. Exploratory data analysis

EDA is in 04_eda_reject_effectiveness.ipynb. Its purpose was not to browse the data but to answer three questions that determine whether modelling is viable at all.

6.1 Does the target have usable variance?

The target is defined strictly: reject “works” only if the tracker count falls to exactly zero. From a GDPR standpoint a refusal should mean no non-essential tracking at all, so a partial reduction is not compliance.

Target balance — 1,583 sites where the reject test completed

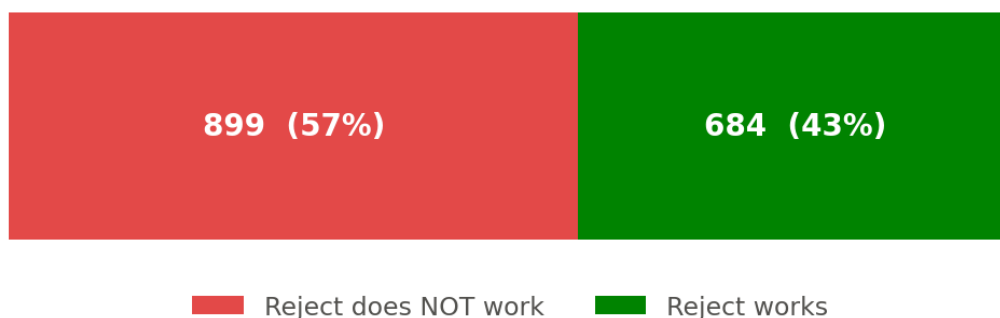


Figure 1 - Class balance of the target variable.

The split is 57% / 43% - well balanced. That means no resampling was required, and more importantly that a model has something real to learn: had one class held 95% of the rows, a model could score 95% accuracy while learning nothing at all. It also frames the headline result in its own right - on sites where the test could run, clicking reject failed to stop the tracking more often than it worked.

6.2 Do the candidate features separate the two classes?

Every candidate feature was grouped by outcome and compared. The strongest separation comes from pre-consent tracking intensity, and it is close to monotonic.

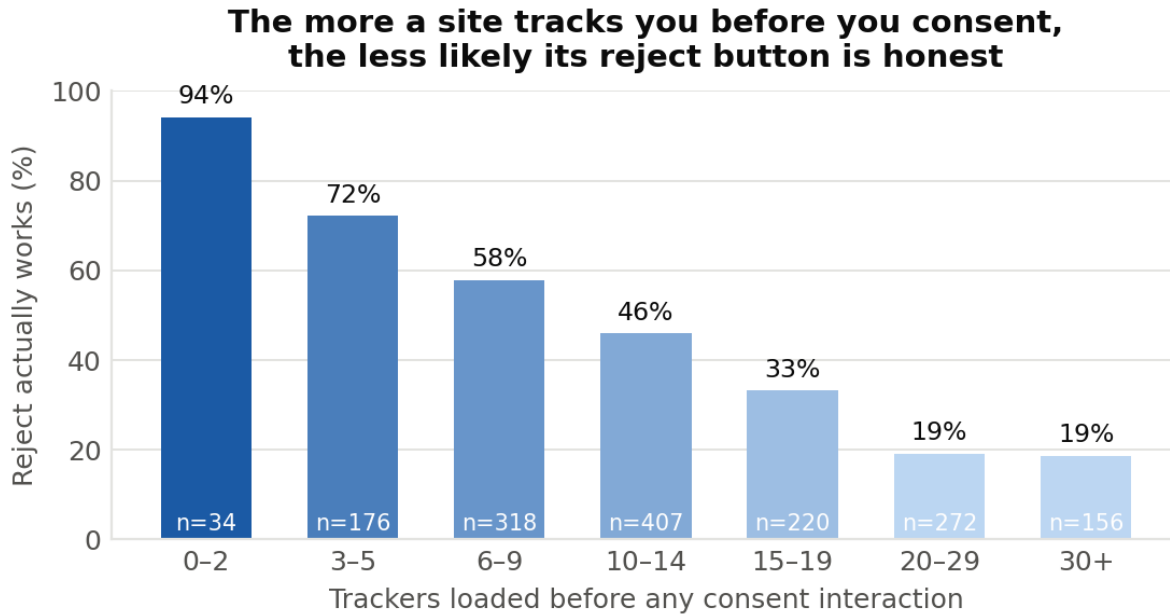


Figure 2 - Reject effectiveness as a function of pre-consent tracking intensity.

Sites loading fewer than three trackers before any interaction honour the reject click 94% of the time. Sites loading twenty or more honour it 19% of the time. The relationship declines steadily across every bucket in between, which is exactly the shape a useful feature should have - and it is why tracker and ad-network counts dominate the model's feature importances in section 11.

The plain-language version: the more a site is tracking you before you have agreed to anything, the less likely it is to stop when you refuse. Sites that respect a refusal tend to be the sites with less to lose by respecting it.

The consent platform separates the classes too, and far more dramatically than expected.

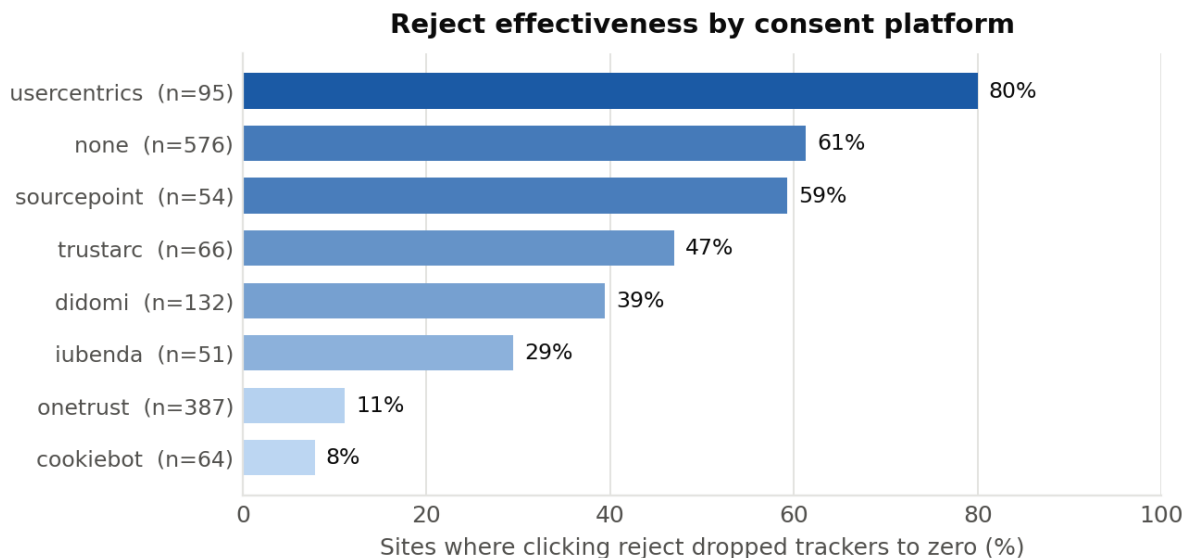


Figure 3 - Reject effectiveness by consent platform, for vendors with at least 50 tested sites.

The spread runs from 80% down to 8% - a tenfold difference in whether the same user action has any effect. Usercentrics sites honour the reject click 80% of the time; Cookiebot sites 8% and OneTrust sites 11%, despite OneTrust being the most widely deployed platform in the sample (Figure 6).

Two cautions on reading this chart, both of which matter for fairness. First, it measures platforms as configured in the wild, not the platforms themselves - every one of these vendors can be configured to honour a refusal, and a low bar most likely reflects the default settings their customers deploy rather than a technical incapacity. Second, the ranking correlates with the kind of site that chooses each vendor, and the enterprise platforms are chosen by exactly the heavily commercial sites that Figure 2 shows are least likely to honour a refusal.

That second point was tested rather than assumed. Within OneTrust alone, sites where reject fails carry more trackers than sites where it works - so ad-tech density is doing the work, and the vendor is substantially a proxy for it. The same check explains the "none" bar sitting high at 61%: sites with no recognised platform are mostly small, low-tracker sites with a hand-built banner, and a site with little to hide has little reason to build a dishonest reject button.

6.3 Are any features redundant?

A correlation matrix on the numeric features found two problem pairs, both visible as the dark blocks in Figure 4.



Figure 4 - Correlation between the numeric candidate features.

cookies_before_interaction and non_essential_cookies_before_interaction correlate at 0.99 - on these sites nearly every pre-consent cookie is non-essential, so the two columns are effectively the same variable measured twice. tracker_count and ad_network_count correlate at 0.93, which is unsurprising given that ad networks are a subset of trackers.

Redundant features are not free: they dilute importance scores between correlated pairs and add noise without adding signal. The generic cookie count and ad_network_count were dropped, taking the feature matrix from 20 columns to 19.

6.4 The descriptive picture - the SQL layer visualised

Beyond preparing the model, the analysis produced findings in its own right. The queries that generated these figures are listed in section 9; what follows is what they show.

Of 2,398 sites showing a cookie banner, one in three offers no way to refuse

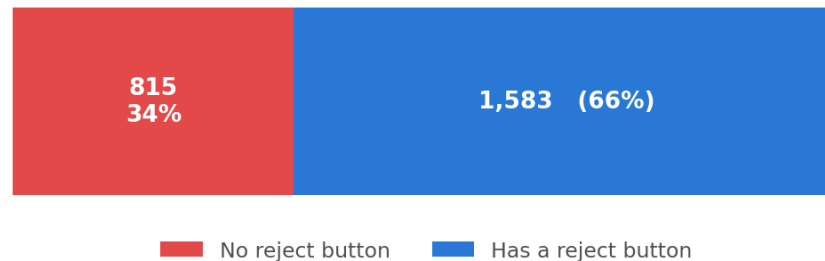


Figure 5 - Reject-button availability among sites that display a cookie banner (Query 1).

This is the headline number and the simplest chart in the report. Of 2,398 sites showing a banner, 815 provide no reject control of any kind. This is not a matter of interpretation or design preference: a banner offering only "accept" cannot produce freely given consent, and a choice with one option is not a choice. It is also the cleanest legal failure in the dataset, because it requires no measurement of what happens after the click - the control simply is not there.

Consent-platform market share (excluding the 2,458 sites with no recognised vendor)

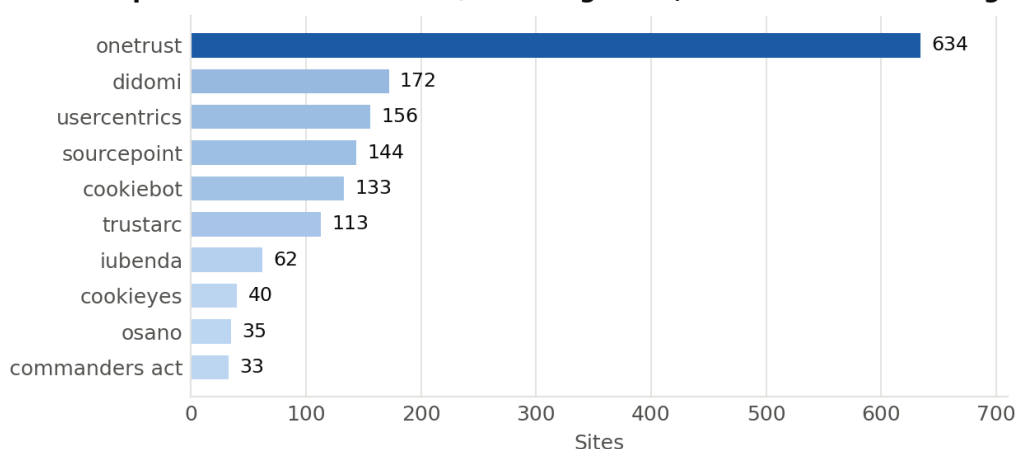


Figure 6 - Consent-platform market share, excluding sites with no recognised vendor (Query 2).

The market is concentrated: OneTrust alone appears on 634 sites, more than the next three vendors combined. The bar excluded from this chart is the largest of all - 2,458 sites, 60% of the sample, run no recognised platform at all. That matters for interpreting Figure 2, because it means the majority of the web is still hand-rolling its consent banners.

Sites with a consent platform carry MORE tracking, not less — confirmed by two independent sources

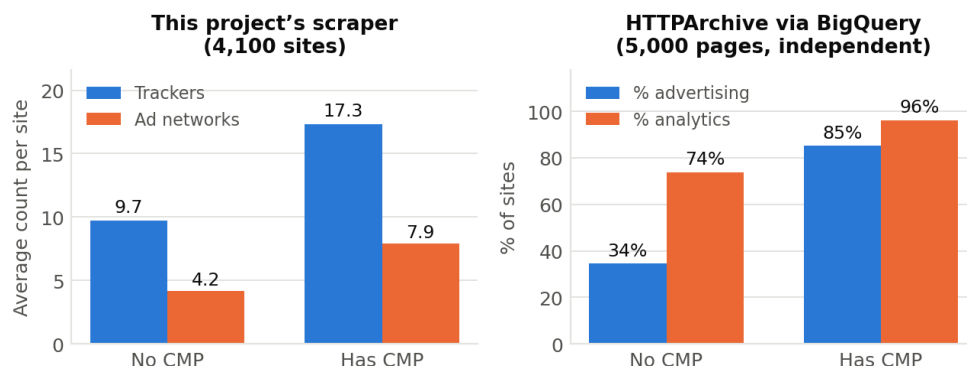


Figure 7 - Tracking intensity by consent-platform status, measured twice by two independent instruments (Queries 3 and 10).

This is the most important figure in the report, and the expected result was the opposite of what it shows. Sites running a consent platform carry roughly 78% more trackers than sites without one - 17.3 against 9.7. The instinctive reading, that consent platforms fail to protect privacy, is not quite right either. The relationship is associative: a site installs a consent platform because it already runs enough third-party technology to need managing. The platform is a symptom of commercial intensity, not a cause of it.

The reason this figure carries the most weight is the right-hand panel. That panel was produced by a different organisation, with different instrumentation, on a different sample of pages, and it reports the same relationship far more sharply: 85% of sites with a consent platform run advertising technology against 34% without. When two independent instruments point the same way, the finding is a property of the web rather than an artefact of how this project happens to count trackers.

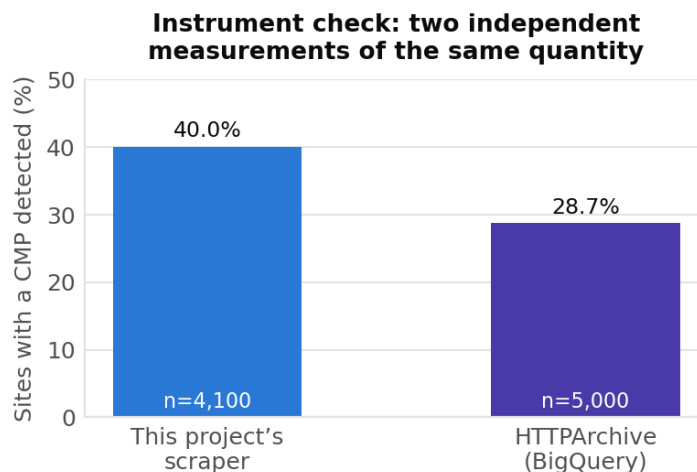


Figure 8 - Cross-checking the scraper against an independent measurement (Query 9).

Before trusting the scraper's output it is worth checking the instrument itself. Both sources measure the same quantity - the share of sites running a consent platform - and they land in the same region: 40.0% from this project's scraper, 28.7% from HTTPArchive. The gap is explained rather than ignored: the scraper recognises custom and self-built banners that Wappalyzer-style technology detection does not fingerprint, so a higher

number is the expected direction. Close enough to confirm the scraper is not systematically wrong; different enough to be informative about what each instrument can see.

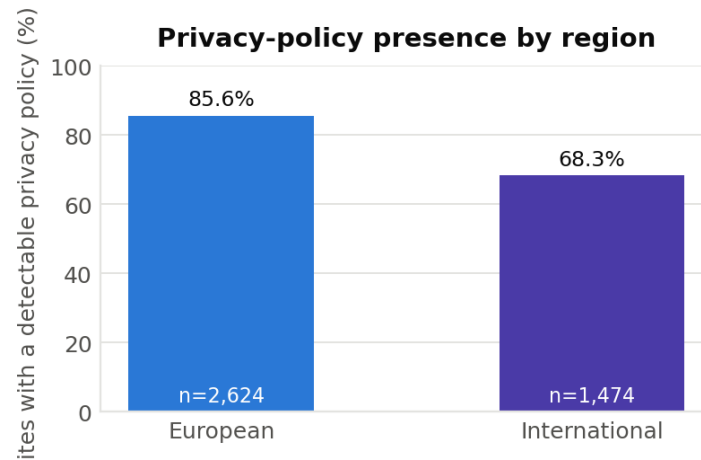


Figure 9 - Privacy-policy presence by region (Query 4).

85.6% of European sites expose a detectable privacy policy against 68.3% of international ones - a 17-point gap. This is consistent with GDPR having shifted baseline behaviour inside its jurisdiction, though the comparison cannot isolate regulation from the other things that differ between the two groups.

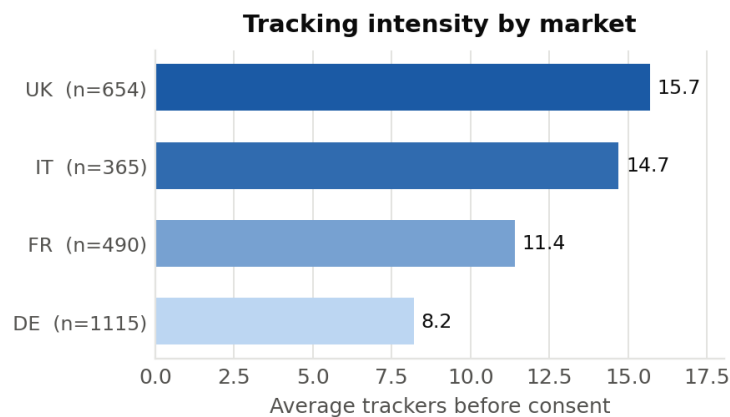


Figure 10 - Average pre-consent trackers by market (Query 5).

Among the major European markets the spread is wide: UK sites average 15.7 trackers, nearly double Germany's 8.2. Germany being the least tracked of the four is consistent with its stricter national data-protection tradition, but with four countries in the comparison this is an observation rather than a conclusion. Sites whose country could not be inferred from the domain suffix are excluded, which removes most .com domains and biases this chart toward sites with a national TLD.

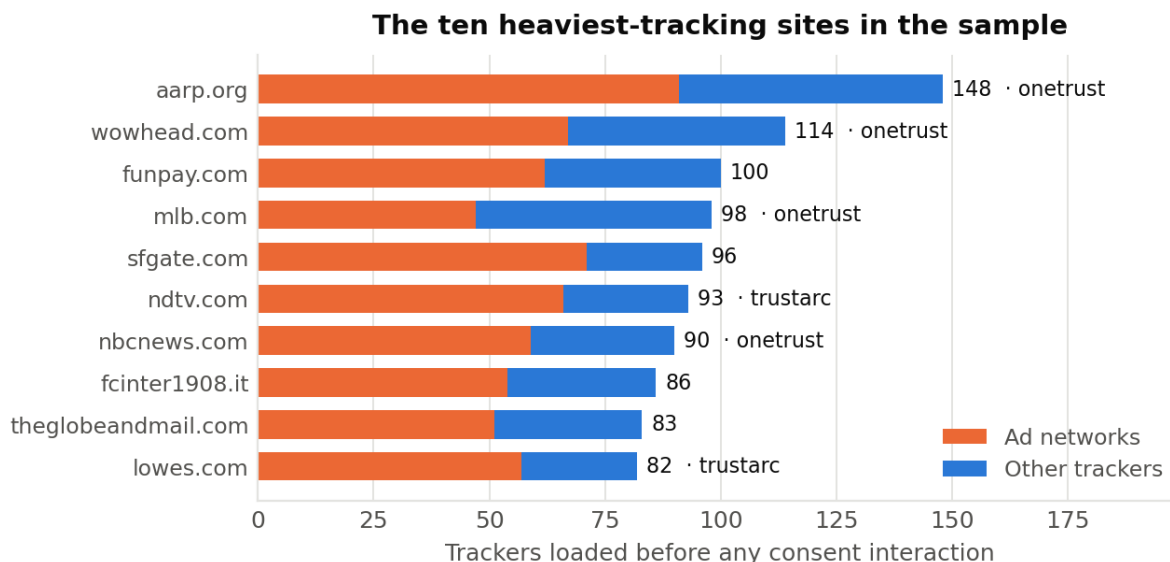


Figure 12 - The ten heaviest-tracking sites, split by tracker type (Query 7).

This is where the analysis stops reporting averages and names individual sites. aarp.org leads with 148 trackers, 91 of them ad networks, before the visitor has agreed to anything. The split shown here is the informative part: for most of these sites the majority of the load is advertising rather than analytics or functional third parties.

Six of the ten run a major commercial consent platform, which is Figure 7's finding restated at the level of individual sites - consent tooling and heavy tracking coexist comfortably. These are reproducible measurements of publicly observable behaviour, and they are reported without any inference about intent.

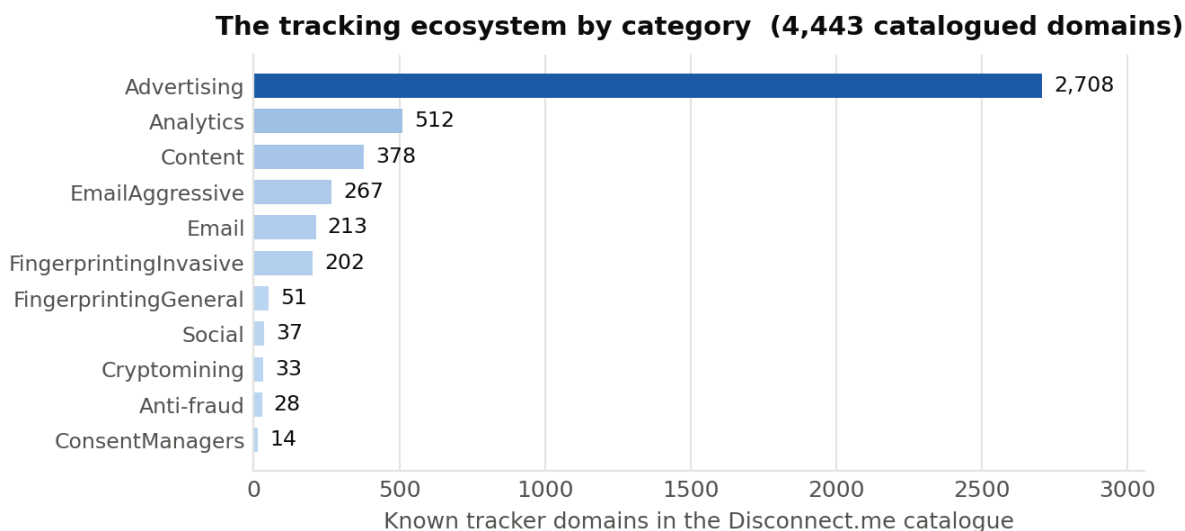


Figure 13 - The Disconnect.me tracker catalogue by category (Query 8).

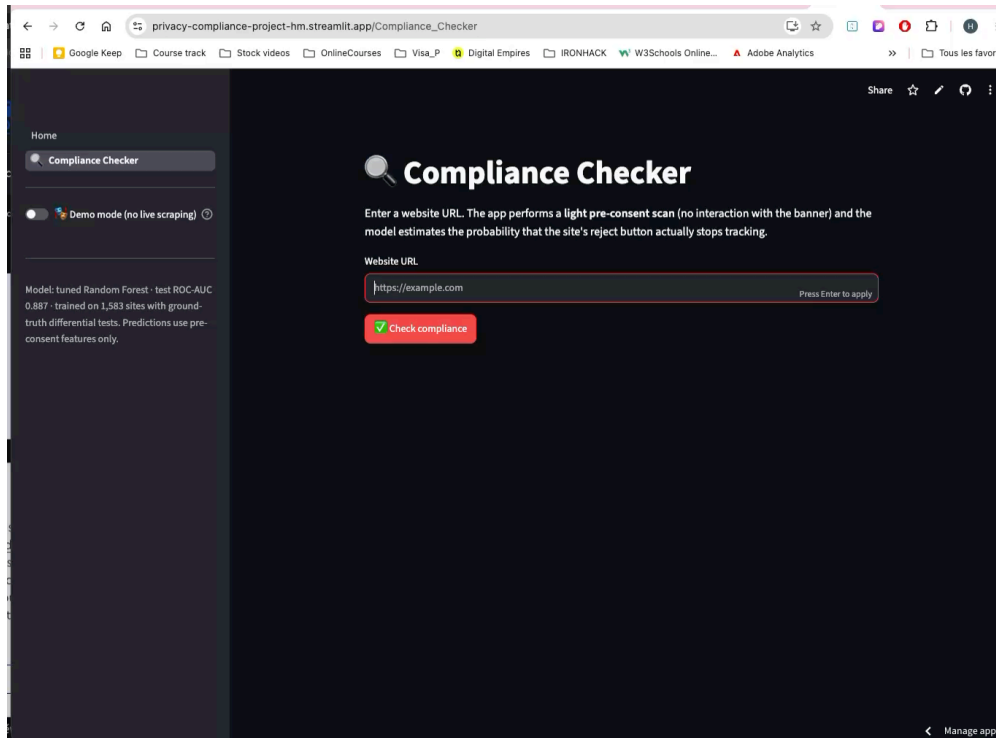
This figure describes the reference catalogue rather than the scanned sites, and it is included for context on the scale of what is being counted. Advertising accounts for 2,708 of 4,443 catalogued domains - more than five times the next category. The 253 domains in the two fingerprinting categories deserve particular note,

because fingerprinting identifies users without setting a cookie at all, and therefore sits outside what a cookie banner can meaningfully consent to in the first place.

6.5 The application

The findings above are exposed interactively in the Streamlit application, alongside the live scoring described in section 11.

Lien vers l'application streamlit : https://privacy-compliance-project-hm.streamlit.app/Compliance_Checker



Entities. ERD

7. Relational database

The cleaned scrape is a single wide flat table - the shape a CSV forces on you, and the shape that makes questions like “which consent vendors appear most often, and do their sites carry more trackers?” awkward to ask. Normalising into MySQL removes the redundancy and makes those questions natural joins.

7.1 Loading approach

Tables are created and populated from pandas through SQLAlchemy rather than through the Workbench import wizard. This is deliberate: the wizard infers types unreliably on wide tables with many booleans and nulls, and - more importantly - a notebook is reproducible where a GUI import is not. Re-running the setup notebook rebuilds the entire database from the cleaned CSVs.

```
engine = create_engine(f'mysql+pymysql://root:{PASSWORD}@localhost/{DB_NAME}')

sites_table.to_sql('sites', engine, if_exists='replace', index=False)
cmps_table.to_sql('cmps', engine, if_exists='replace', index=False)
scans_table.to_sql('scans', engine, if_exists='replace', index=False)
trackers_table.to_sql('trackers', engine, if_exists='replace', index=False)
df_bigquery.to_sql('bigquery_technologies', engine, if_exists='replace', index=False)
```

The password is URL-encoded once with `quote_plus` and all credentials are read from a `.env` file that is git-ignored, so no secret is committed.

```
# Keep only the columns relevant to a 'site' as an entity (not scan results -
# those belong in their own table, see Step 7)
sites_table = df_urls[['domain', 'country', 'region']].drop_duplicates(subset='domain').reset_index(drop=True)

# Every table needs a primary key. We make one up here: row position + 1
# (so IDs start at 1, like a normal database, instead of 0)
sites_table['site_id'] = sites_table.index + 1

print(sites_table.shape)
sites_table.head()
```

```
def normalize_cmp_name(name):
    """Lowercases, strips, and maps known aliases to one canonical name."""
    if pd.isna(name):
        return 'none'

    clean = name.strip().lower()

    aliases = {
        'commanders act trustcommander': 'commanders act',
        'trustcommander': 'commanders act',
        'fundingchoices': 'funding choices',
        'snigel adconsent': 'snigel',
        'conversant consent tool': 'conversant',
        # Generic/custom banner names -- no recognized vendor
        'cookie notice': 'none',
        'cookie script': 'none',
        'custom cookie banner': 'none',
    }

    return aliases.get(clean, clean)
```

7.2 Normalisation

Dimension tables were built in pandas and foreign keys inserted into the fact table before loading. The sites table was derived from the cleaned Tranco list with a surrogate primary key; the cmps lookup was built from the union of vendor names across both the scraper and BigQuery, after the alias normalisation described in §5.1; and the scans fact table was produced by merging the scrape onto sites on domain and onto cmps on the normalised vendor name. Sites with no recognised vendor correctly receive a null cmp_id.

8. Entity-relationship diagram

Five entities, exceeding the required four; three of the four relationships are enforced by keys.

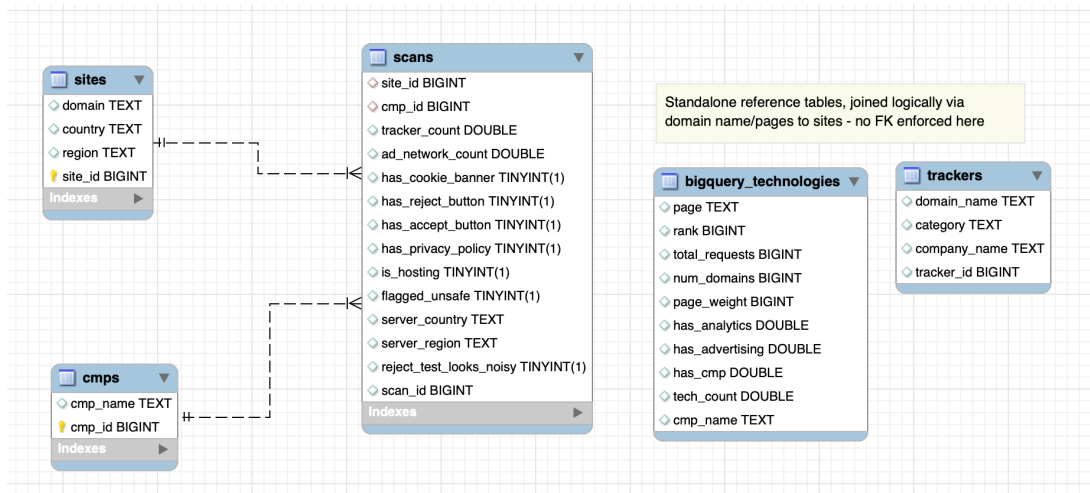


Figure 14 - Entity-relationship diagram of the privacy_scorer database.

Relationship	Type	Implementation
sites → scans	1 : N	scans.site_id references sites.site_id - one site can be scanned repeatedly over time
cmps → scans	1 : N	scans.cmp_id references cmps.cmp_id - nullable, since a site may run no recognised platform
trackers ↔ scans	N : M (logical)	Resolved during scraping by matching observed third-party domains against the catalogue; the catalogue is kept as a queryable reference table
bigquery_technologies → sites	Logical join on domain	Held deliberately unconstrained so the cross-validation source stays fully independent of the scraper

Table 4 - Relationships in the schema.

The last two rows are a design decision rather than an omission. Constraining the BigQuery table to sites would force its rows to conform to the scraper's population, which would defeat its entire purpose: it is valuable precisely because it is an independent measurement, and section 9 uses it to test whether the scraper's findings hold up against an outside instrument.

9. SQL analysis and insights

Ten queries were written against the database; the five carrying the principal findings are presented here. The full set, with commentary, is in 06_sql_insight_queries.sql, and every result is exported to clean_data/sql_query_exports/. This section gives the SQL and the numbers; the results are charted and interpreted in §6.4, Figures 5 to 13.

Query 1 - Banners that offer no way to refuse

```
SELECT has_cookie_banner, has_reject_button, COUNT(*) AS num_sites
FROM   scans
WHERE  has_cookie_banner = TRUE
GROUP BY has_cookie_banner, has_reject_button;
```

Result: of 2,398 sites displaying a cookie banner, 1,583 offer a reject control and **815 - 34% - offer none at all**. One banner in three is accept-only.

This is the headline finding. It is also a straightforward legal failure rather than a matter of interpretation: a banner with no reject path cannot produce valid consent under the GDPR, because consent must be freely given, and a choice with one option is not a choice.

Query 3 - Do consent platforms reduce tracking?

```
SELECT CASE WHEN c.cmp_name = 'none' OR c.cmp_name IS NULL
           THEN 'No recognized CMP' ELSE 'Has recognized CMP' END AS cmp_status,
       COUNT(*) AS num_sites,
       ROUND(AVG(sc.tracker_count), 1) AS avg_trackers,
       ROUND(AVG(sc.ad_network_count), 1) AS avg_ad_networks
FROM   scans sc
LEFT JOIN cmps c ON sc.cmp_id = c.cmp_id
GROUP BY cmp_status;
```

CMP status	Sites	Avg. trackers	Avg. ad networks
Has recognised CMP	1,642	17.3	7.9
No recognised CMP	2,458	9.7	4.2

Table 5 - Tracking intensity by consent-platform status.

The expected result was the opposite. Sites running a consent platform carry roughly 78% more trackers than sites without one. The reading is not that consent platforms cause tracking, but that they are a symptom of it: a site installs one because it already runs enough third-party technology to need managing. Consent platform presence is therefore a marker of commercial intensity, not of privacy protection - which matters, because it is frequently presented as the latter.

Query 10 - The same question, asked of an independent dataset

A finding that surprising has to be tested against another instrument. This query asks it of BigQuery's own technology detections, which have nothing to do with this project's scraper.

```
SELECT CASE WHEN has_cmp = 1 THEN 'Has CMP' ELSE 'No CMP' END AS cmp_status,
       COUNT(*) AS num_sites,
       ROUND(100.0 * SUM(has_advertising) / COUNT(*), 1) AS pct_with_advertising,
       ROUND(100.0 * SUM(has_analytics) / COUNT(*), 1) AS pct_with_analytics,
       ROUND(AVG(tech_count), 1) AS avg_tech_count
```

```
FROM bigquery_technologies
GROUP BY cmp_status;
```

CMP status	Sites	% advertising	% analytics	Avg. technologies
Has CMP	1,437	85.2	96.0	25.9
No CMP	3,563	34.5	73.8	13.8

Table 6 - The same relationship measured on an independent dataset.

The pattern not only holds, it is far more pronounced: 85.2% of sites with a consent platform run advertising technology against 34.5% without. Two independent instruments, two different samples, the same direction. This is the strongest result in the project, because it is the one least likely to be an artefact of how the scraper counts.

Query 4 - Privacy policies by region

```
SELECT s.region, COUNT(*) AS num_sites,
       SUM(CASE WHEN sc.has_privacy_policy THEN 1 ELSE 0 END) AS sites_with_policy,
       ROUND(100.0 * SUM(CASE WHEN sc.has_privacy_policy THEN 1 ELSE 0 END)
             / COUNT(*), 1) AS pct_with_policy
FROM   sites s JOIN scans sc ON s.site_id = sc.site_id
GROUP BY s.region;
```

Result: 85.6% of European sites (2,245 of 2,624) expose a detectable privacy policy, against 68.3% of international ones (1,007 of 1,474) - a 17-point gap consistent with GDPR having changed baseline behaviour in its jurisdiction.

Query 9 - Validating the scraper against BigQuery

A measurement instrument should be checked before its output is trusted. This query computes the scraper's own consent-platform detection rate so it can be compared with BigQuery's independent figure.

```
SELECT COUNT(*) AS total_scans,
       SUM(CASE WHEN c.cmp_name != 'none' THEN 1 ELSE 0 END) AS scans_with_cmp,
       ROUND(100.0 * SUM(CASE WHEN c.cmp_name != 'none' THEN 1 ELSE 0 END)
             / COUNT(*), 1) AS pct_with_cmp
FROM   scans sc JOIN cmps c ON sc.cmp_id = c.cmp_id;
```

Result: the scraper detects a consent platform on 40.0% of sites (1,642 of 4,100); BigQuery reports 28.7% (1,437 of 5,000). The gap is explained by the scraper recognising custom and self-built banners that Wappalyzer-style detection misses. The two are close enough to confirm the scraper is not systematically wrong, and the residual difference is itself informative.

Further findings from the remaining queries

- Tracking intensity by market (Query 5): UK 15.7 trackers on average, Italy 14.7, France 11.4, Germany 8.2 - Germany the least tracked of the major European markets by a wide margin.
- Hosting (Query 6): sites on commercial hosting or cloud infrastructure average 13.8 trackers against 10.2 for self-hosted, consistent with cloud hosting being a marker of commercial scale.
- Worst offenders (Query 7): aarp.org leads with 148 trackers and 91 ad networks, followed by wowhead.com at 114 and funpay.com at 100. Several run a major consent platform - high tracker counts and consent tooling coexist comfortably.

- Ecosystem scale (Query 8): of 4,443 catalogued trackers, 2,708 are advertising and 512 analytics, with 253 in fingerprinting categories that operate without cookies at all.
- Safety (Query 6): zero sites flagged by Safe Browsing, confirming the consent failures documented here belong to the mainstream web, not to disreputable corners of it.

API

The database is meant to be consumable by other applications, not only by the Streamlit front end. A Flask REST API sits over the `privacy_scorer` database and exposes two resources across four endpoints. It lives in the `api/` folder of the repository and reuses the same SQLAlchemy engine and `.env` credentials as the notebooks, so it reads the live MySQL database directly.

Endpoint	Method	Returns
<code>/api/sites</code>	GET	Paginated site collection (limit / offset), filterable by region, country and minimum tracker count
<code>/api/sites/<domain></code>	GET	A single site with its scan result and consent-platform name nested in the response
<code>/api/scans</code>	GET	Paginated scan collection, filterable by <code>cmp_name</code> , <code>has_reject_button</code> and banner presence
<code>/api/scans/<scan_id></code>	GET	A single scan in full detail, with its site and consent platform nested

Table 7 - API surface: two resources, four endpoints.

Each collection endpoint paginates with limit and offset - limit is capped at 100 so a client cannot request an entire table - and returns a meta block giving the total row count, the count returned and the filters applied. The single-object endpoints nest related data, so a request for a site returns its scan and consent vendor in one response rather than forcing a second call. A root route at `/` documents every endpoint, and a `/api/health` route confirms database reachability.

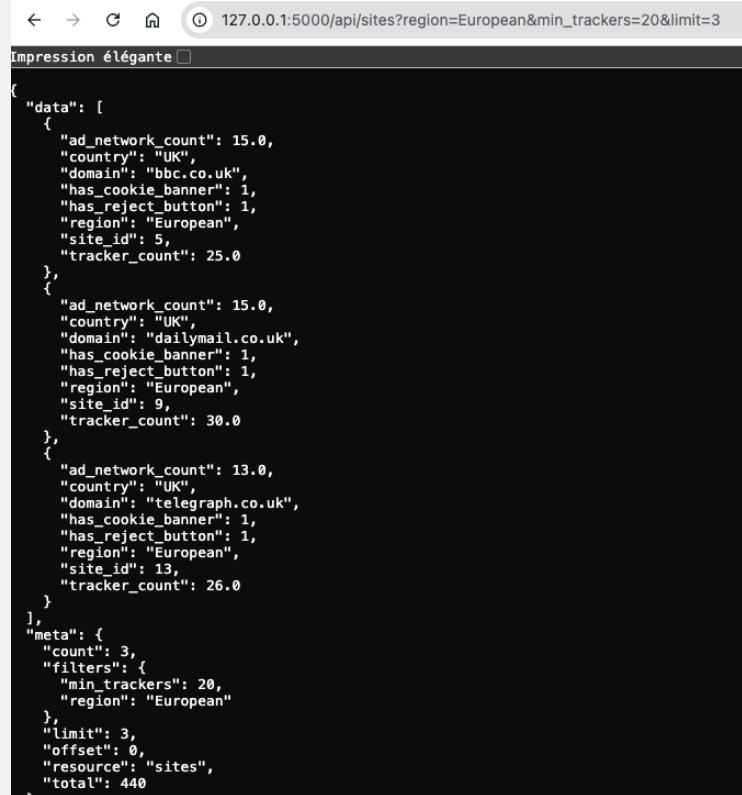
10.1 Correctness and safety

Every value supplied by the client - filter arguments, the domain in the path, the scan id - is passed to the database as a bound parameter through SQLAlchemy's `text()` construct, never formatted into the SQL string. That closes the door on SQL injection: a request for the path `/api/sites/x';DROP TABLE sites;--` is treated as a literal domain, matches nothing, and returns a plain 404 with the table untouched. Malformed filters return 400 with a JSON message (`min_trackers=lots`, `has_reject_button=maybe`), unknown identifiers and routes return 404, and every error response is JSON rather than an HTML error page.

10.2 Worked examples

A filtered, paginated collection request : European sites carrying at least 20 trackers:

```
GET /api/sites?region=European&min_trackers=20&limit=3
```



```
{
  "data": [
    {
      "ad_network_count": 15.0,
      "country": "UK",
      "domain": "bbc.co.uk",
      "has_cookie_banner": 1,
      "has_reject_button": 1,
      "region": "European",
      "site_id": 5,
      "tracker_count": 25.0
    },
    {
      "ad_network_count": 15.0,
      "country": "UK",
      "domain": "dailymail.co.uk",
      "has_cookie_banner": 1,
      "has_reject_button": 1,
      "region": "European",
      "site_id": 9,
      "tracker_count": 30.0
    },
    {
      "ad_network_count": 13.0,
      "country": "UK",
      "domain": "telegraph.co.uk",
      "has_cookie_banner": 1,
      "has_reject_button": 1,
      "region": "European",
      "site_id": 13,
      "tracker_count": 26.0
    }
  ],
  "meta": {
    "count": 3,
    "filters": {
      "min_trackers": 20,
      "region": "European"
    },
    "limit": 3,
    "offset": 0,
    "resource": "sites",
    "total": 440
  }
}
```

A single-object request, showing the scan and consent vendor nested inside the site rather than returned as separate resources:

```
GET /api/sites/bbc.co.uk
```



```
{
  "country": "UK",
  "domain": "bbc.co.uk",
  "region": "European",
  "scan": {
    "ad_network_count": 15.0,
    "cmp_name": "none",
    "flagged_unsafe": 0,
    "has_accept_button": 1,
    "has_cookie_banner": 1,
    "has_privacy_policy": 1,
    "has_reject_button": 1,
    "is_hosting": 1,
    "reject_test_looks_noisy": 0,
    "scan_id": 3,
    "server_country": "Canada",
    "server_region": "Quebec",
    "tracker_count": 25.0
  },
  "site_id": 5
}
```

The endpoints were tested against the live 5,000-site database; the responses above are real output. Full documentation, including the filter tables and the error catalogue, is in [api/README.md](#).

11. Machine learning

11.1 Problem framing

Binary classification: given only signals observable before any consent interaction, predict whether clicking reject will drive the tracker count to zero. The modelling population is the 1,583 sites where the differential test actually completed and a genuine label exists.

The discipline that matters most here is leakage avoidance. Two columns had to be excluded explicitly: `tracker_count_after_reject`, which is the answer restated, and `reject_click_succeeded`, which cannot be known until the interaction has already happened. A model using either would score superbly and be useless in the application, which by construction has only pre-consent data available.

11.2 Feature engineering and selection

- The raw hosting organisation column contains hundreds of distinct values, far too many to encode usefully. It was collapsed into a single boolean, `uses_major_cloud_cdn`.
- Consent vendors with very few sites were grouped into an "other" category so the model does not learn a rule from two observations, then one-hot encoded.
- Redundant correlated features were dropped as described in §6.3, leaving 19 features.
- Features were scaled for Logistic Regression only; the three tree-based models were trained on unscaled data, which they handle natively.

11.3 Baseline

Predicting the majority class for every site yields 56.8% accuracy. That is the number any model has to beat convincingly to be worth deploying, and it is stated first so that later accuracy figures can be read in context rather than admired in isolation.

11.4 Model comparison

Four algorithms were trained in default configuration and then tuned with GridSearchCV, using cross-validated F1 for selection. Results on the held-out test set (317 sites):

Model (tuned)	Accuracy	ROC-AUC	Note
Decision Tree	0.820	0.845	Best accuracy; coarse probabilities - few distinct values
XGBoost	0.814	0.878	Best ROC-AUC
Random Forest	0.801	0.872	Selected - see below
Logistic Regression	0.763	0.853	Respectable, indicating a largely linear relationship
Majority-class baseline	0.568	-	The number to beat

Table 8 - Tuned model performance on the held-out test set.

11.5 Model selection, and an honest note on it

Accuracy and ROC-AUC disagree here, and ROC-AUC is the metric that matters for this application. The Streamlit app displays a probability - “27% chance this reject button is honoured” - rather than a bare label, so the quality of the ranking matters more than accuracy at an arbitrary 0.5 cutoff. On that criterion the Decision Tree is eliminated despite leading on accuracy: a shallow tree produces only a handful of distinct probability values, one per leaf, so its apparent accuracy advantage does not translate into useful probability estimates.

Random Forest was selected as the final model. It should be stated plainly that XGBoost edges it on both metrics - 0.878 against 0.872 on ROC-AUC, and 0.814 against 0.801 on accuracy. The margin on ROC-AUC is 0.006, which is within the noise of a 317-row test set. Random Forest was preferred at essentially equivalent ranking performance because it yields directly interpretable feature importances, which are central to this project: the point is not only to predict which reject buttons are dishonest but to explain what makes them so. Where a project needed the last fraction of predictive performance rather than an explanation, XGBoost would be the correct choice on these numbers.

One assumption going into this comparison turned out to be wrong, and correcting it is part of the result. The expectation was that a single Decision Tree would overfit and that an ensemble would be the remedy. The train/test gaps say the reverse: the Decision Tree generalised cleanly (gap -0.034) while the untuned Random Forest overfitted badly, scoring 0.991 on train against 0.808 on test - a gap of 0.184. GridSearchCV’s `min_samples_split=5` is what closes it, so the tuned Random Forest is the model to trust and the default is not. The tree’s real weakness here is coarse probability output, not overfitting.

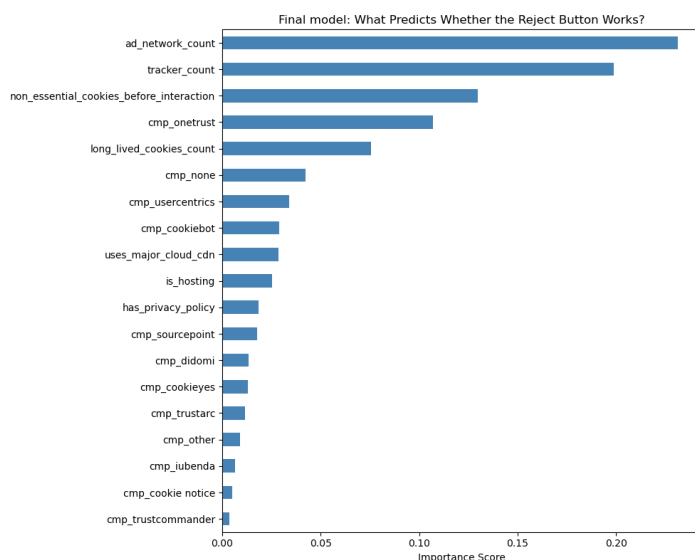
Final model: Random Forest (tuned) - 80.1% accuracy, 0.872 ROC-AUC, against a 56.8% baseline.
Hyperparameters: `n_estimators=300`, `max_depth=None`, `max_features='sqrt'`, `min_samples_split=5`.

FINAL MODEL — Random Forest (tuned)

The two metrics disagree, so the choice has to be argued rather than read off a table.

The tuned results:

Model (tuned)	Accuracy	ROC-AUC
Decision Tree	0.820	0.845
XGBoost	0.814	0.878
Random Forest	0.801	0.872
Logistic Regression	0.763	0.853



11.6 What the model learned

Feature	Importance	Interpretation
ad_network_count	0.231	Ad networks loading before consent is the strongest single signal
tracker_count	0.199	Overall pre-consent tracking intensity
non_essential_cookies_before_interaction	0.130	Cookies set that legally required prior consent
cmp_onetrust	0.107	The specific consent vendor carries signal of its own
long_lived_cookies_count	0.075	Cookies exceeding the CNIL 13-month recommendation

Table 9 - Top five features by importance in the final tuned Random Forest.

The finding is coherent and, on reflection, unsurprising: the more advertising technology a site loads before you have agreed to anything, the less likely its reject button is honest. Sites that respect refusal tend to be the sites with less to lose by respecting it. Because `tracker_count` and `ad_network_count` remain correlated at roughly 0.93, their importances should be read as one shared signal split across two columns rather than two independent effects.

11.7 Deployment

The tuned model and its feature-column list are serialized to `models/` with `joblib` and loaded by the Streamlit application. At scoring time the app performs a light pre-consent scrape, assembles exactly the feature vector the model expects, and displays `predict_proba` as a risk score. A demo mode with a canned example is included so a live presentation does not depend on venue wi-fi or on a website behaving as expected.

12. Conclusions, limitations and GDPR

12.1 Principal findings

- One cookie banner in three offers no way to refuse - 815 of 2,398 sites with a banner, 34%. This is not a grey area; it is a direct failure of the GDPR requirement that consent be freely given.
- Consent management platforms are a marker of tracking intensity, not of privacy protection. Sites running one average 17.3 trackers against 9.7 for sites without. The relationship is associative, not causal - a platform appears where there is already a great deal to manage.
- That finding replicates on a fully independent dataset: 85.2% of BigQuery-sampled sites with a consent platform run advertising technology against 34.5% without. Two instruments, one conclusion.
- Whether a reject button works depends heavily on which consent platform is deployed - from 80% effectiveness on Usercentrics sites down to 11% on OneTrust and 8% on Cookiebot. This reflects how each platform is configured in the wild and which sites choose it, not the vendors' technical capability.
- Reject effectiveness falls steadily with pre-consent tracking intensity, from 94% on the lightest-tracking sites to 19% on the heaviest - the single clearest relationship in the data.
- Regulation appears to shift baseline behavior: 85.6% of European sites expose a privacy policy against 68.3% of international ones.
- Dishonest reject buttons are predictable from pre-consent signals alone, at 80.1% accuracy and 0.872 ROC-AUC - which means a cheap scan can triage which sites merit an expensive manual audit.

12.2 Limitations

- The success criterion is strict - exactly zero trackers after reject. Some residual requests may be genuinely strictly necessary and therefore lawful. A sensitivity analysis redefining success as a $\geq 90\%$ reduction would test how much the headline figures depend on this choice.
- The modelling population is not the full sample. Labels exist only for the 1,583 sites where the reject click could be automated, and sites that defeat automation may differ systematically from those that do not. This is the most serious threat to generalisation in the project.
- The population is drawn from Tranco-ranked popular domains, so conclusions extend to the mainstream web rather than to the long tail of smaller sites.
- Every measurement is a snapshot. Sites change consent configuration frequently, and the model would need periodic re-scraping to stay accurate.
- reject_as_visible_as_accept was collected but not modelled, and it is arguably closer to the CNIL's actual legal standard - visual parity between the two controls - than the functional test used here.

12.3 GDPR and ethical considerations

A project that audits privacy compliance has an obvious obligation to be compliant itself.

- **No personal data was collected or processed.** The unit of observation is a website, not a person. The scraper records technical properties of pages - third-party request domains, cookie counts and expiry durations, DOM structure. No user data, no account data, no content is stored, and the project processes no personal data within the meaning of Article 4(1) GDPR. It therefore requires no lawful basis under Article 6 and creates no data-subject rights to service.

- **Cookies were observed, never used.** The scraper counts cookies as measurements and discards them with each browser session. Nothing is persisted and nothing is used to track anything.
- **Only publicly accessible pages were accessed.** The audit visits public home pages exactly as an ordinary visitor would. No authentication was bypassed, no paywall circumvented, no non-public area accessed.
- **Scraping was conducted responsibly.** robots.txt presence was recorded, requests were rate-limited, and each site was visited a small number of times. The load imposed is negligible relative to normal traffic on domains of this popularity.
- **Named sites are reported factually.** Query 7 identifies individual domains by name. These are reproducible technical measurements of publicly observable behavior, reported without inference about intent - a high tracker count is a fact about a page, not an accusation of wrongdoing, and the report does not present it as one.
- **Credentials are not committed.** Database passwords and API keys are read from a git-ignored .env file.

12.4 Next steps

- Deploy the Flask API (section 10) and the Streamlit application publicly, behind a hosted MySQL instance, so both are reachable without a local database.
- Broaden the sample beyond Tranco-ranked domains to include long-tail and non-European sites, testing whether the model generalizes.
- Model the visual-parity signal, bringing the measurement closer to the CNIL's actual legal standard.
- Re-scrape periodically to build a longitudinal view - whether consent behavior improves as enforcement intensifies is a more valuable question than any single snapshot can answer.

12.5 Sources and references

- Tranco - a research-oriented top-sites ranking: <https://tranco-list.eu/>
- HTTPArchive public BigQuery dataset: <https://httparchive.org/faq>
- Disconnect.me tracking protection lists: <https://github.com/disconnectme/disconnect-tracking-protection>
- Google Safe Browsing API: <https://developers.google.com/safe-browsing/reference>
- ip-api IP geolocation service: <https://ip-api.com/>
- CNIL - guidelines and recommendation on cookies and trackers: <https://www.cnil.fr/>
- Regulation (EU) 2016/679 (GDPR), in particular Articles 4, 6 and 7
- Selenium WebDriver and webdriver-manager documentation
- scikit-learn and XGBoost documentation

12.6 Repository

All code, notebooks, data, database scripts, the ERD and the application are available at:

<https://github.com/mhananem/privacy-compliance-project>

The repository README documents the pipeline and the order in which the notebooks must be run to reproduce the results from scratch.